

XXE 漏洞报告

测试目标: Flask XML 数据导入功能

漏洞位置: POST /xml-import

报告日期: 2026-07-14

漏洞概述

XML 导入功能主动提取 `<!ENTITY ... SYSTEM` 中的文件路径并调用 `open()` 读取, 可读取服务器任意本地文件。

漏洞详情

#	攻击向量	Payload	结果
1	读取系统文件	<code>file:///etc/passwd</code>	✓ 读取到 root 用户
2	读取项目源码	<code>file:///app.py</code>	✓ 可读取

Payload 示例

```
<?xml version="1.0"?>
<!DOCTYPE foo [
  <!ENTITY xxe SYSTEM "file:///etc/passwd">
]>
<users>
  <user><name>&xxe;</name><email>test@test.com</email></user>
</users>
```

风险

风险	说明
文件读取	通过 <code>file://</code> 读取任意本地文件

风险	说明
源码泄露	获取 secret_key 和数据库路径

修复方案

移除主动解析 `<!ENTITY ... SYSTEM>` 并读取文件的代码。

```
# 修复前
xxe_pattern = re_mod.findall(r'<!ENTITY\s+(\w+)\s+SYSTEM\s+"([^\"]+)"', xml_data)
for entity_name, filepath in xxe_pattern:
    with open(filepath, "r") as f:
        content = f.read()
        xml_data = xml_data.replace(f"&{entity_name};", content)

# 修复后
root = ET.fromstring(xml_data)
```

修复验证

测试项	修复前	修复后
正常 XML 解析	✓	✓ 正常
XXE 读取 <code>/etc/passwd</code>	✗	✓ 已拦截
XXE 读取 <code>app.py</code>	✗	✓ 已拦截